Performance & Security Report

WEFT — weft-xi-two.vercel.app & weft.runasp.net

Prepared 10 November 2026 · Store: Next.js 16 on Vercel · API: ASP.NET Core 10 on MonsterASP.NET · Database: SQL Server (MonsterASP)

Scope and method

Live checks (measured): response headers and redirects with `curl`, TLS certificates with `openssl`, Lighthouse 13 on mobile (Slow 4G, 4× CPU throttling) and desktop, **3 runs per page, median reported**, latency split into network and server time, login cookie flags, and passive exposure probes (plain GET/HEAD on known paths only). **Source review:** `next.config.ts`, `web.config`, the API's security-header, CSRF, client-IP and rate-limit middleware, validation and error handling. **Dependencies:** `npm audit` and `dotnet list package --vulnerable`.

Not measured: real-user Core Web Vitals (the store has no traffic yet, so there is no field data), INP (needs real interactions), and load capacity: no load was generated against the free hosting plan. No intrusive or active security testing was performed. Measurements were taken from Cairo, about 150 ms round-trip from the servers.

> Status key: **OK** observed and sound · **CHECK** cannot be confirmed from here (Section 4 lists the tool for each) · **FIX** issue visible in the page, configuration or code. Section 6 is a modelled calculation, not a measurement.

Summary

Good: the store is fast and well protected. On desktop, Lighthouse scores 100 (home) and 98 (product), with every page painting in under 0.5 s. Accessibility and best practices are 100 after this review's fixes. Both hosts serve HTTPS with HSTS, the API sends a strict security-header set, the owner's login cookie is `Secure; HttpOnly; SameSite=Strict`, rate limits are active, and no secrets, source maps or configuration files are publicly reachable. **Main performance risk:** the shop page's largest element appears at 2.8 s on a throttled phone (target 2.5 s), and the free API host may sleep when idle. **Main gaps:** share links, canonical tags and the sitemap point to the wrong domain; there is no database backup (the photos live in the database too); order emails are not actually sent; and the public GitHub repository's history shows the database server name and user.

Area	Finding	Status
Performance (desktop)	Home 100 / product 98; LCP 456 ms / 374 ms	OK
Performance (mobile, throttled)	Home 98, product 90, shop 85; shop LCP 2.81 s	FIX
Delivery	Vercel CDN (Frankfurt edge, cache HIT); Brotli on API JSON; API responses cached at the edge	OK
Transport	HTTPS on both hosts, HTTP→HTTPS redirect, HSTS, valid certificates	OK
Security headers	Full set on both; store CSP is still Report-Only	CHECK
Login and API protection	Secure/HttpOnly/SameSite=Strict cookie, CSRF header, rate limits, admin 401 without login	OK
Exposure	No .env, .git, web.config, OpenAPI, source maps or secrets in client JavaScript	OK
Canonical, share links, sitemap	Point to weft.vercel.app (a domain you do not own)	FIX
Repository	Public; history shows the database server and user (the database is internet-reachable)	FIX
Backups	No backup job for the database (products, orders and photos)	FIX
Order emails	Log-only sender: owner and customers receive no email	FIX
Dependencies	Production: 0 vulnerabilities (npm and .NET); GitHub vulnerability alerts off	FIX

1. Performance

Measured (Lighthouse 13, median of 3 runs)

Page	Device	Perf	FCP	LCP	TBT	CLS	Weight	Requests
Home	Desktop	100	456 ms	456 ms	0 ms	0	374 KB	28
Product	Desktop	98	374 ms	374 ms	32 ms	0.006	377 KB	30
Home	Mobile	98	1130 ms	1130 ms	141 ms	0.001	374 KB	28
Product	Mobile	90	1555 ms	1555 ms	387 ms	0.001	377 KB	30
Shop	Mobile	85	1018 ms	2808 ms	394 ms	0	384 KB	29

Mobile = Slow 4G + 4× CPU slowdown. Product page is after this review's preload fix (before: LCP 2,811 ms, score 87).

What the site shows

Observation	Impact	Status
Hosting: store on Vercel, served from the Frankfurt edge (`x-vercel-id: fra1` , `X-Vercel-Cache: HIT`); API on MonsterASP (IIS, x86)	Static pages come from a CDN near Egypt	**OK**
Server time: about one round-trip (~150 ms from Cairo); the rest is TCP/TLS set-up (~450 ms on a new connection)	Code is not the bottleneck; distance is	**OK**
Compression: API JSON sent with Brotli (`Content-Encoding: br`)	Smaller responses	**OK**
Images: products saved as WebP 400/800/1600 with `srcset` ; hero 49 KB WebP; logos are WebP at 2× display size	Small, correct-size images	**OK**
Product photos are stored in SQL Server and served at `/api/media/…` with a one-year cache that Vercel's edge honours	Each photo leaves the database once per edge region. Not yet observed with real photos (none uploaded)	**CHECK**
LCP element (product): main product image, now preloaded by the server with `fetchPriority="high"`	LCP 2.81 s → 1.56 s on mobile	**OK**
LCP element (shop): a heading/count line that waits for the product list from the API; the shop is a client-side section of the home page	LCP 2.81 s on throttled mobile (target 2.5 s)	**FIX**
JavaScript: views are code-split (cart, orders, tracking, admin load on demand); no third-party scripts	TBT 0–387 ms; ~30 KB of unused JS per page	**OK**
Fonts: Tajawal and DM Sans via `next/font` (self-hosted WOFF2, swap, preloaded)	No font flash or layout shift	**OK**
Caching: hashed Next.js assets `immutable` ; public API reads cached 60–300 s at API and edge	Owner edits show within about 1–2 minutes	**OK**
Idle sleep: free IIS app pools usually stop after inactivity	First visitor after a quiet period may wait several seconds	**CHECK**

Recommendations

- **Shop page LCP:** render the shop heading and product count without waiting for the API, or server-render the shop list. With 4 products this is polish, not urgent.
- **Keep the API awake:** an uptime monitor calling `https://weft.runasp.net/health` every 5 minutes (UptimeRobot, free) also alerts you if the site goes down.
- **After uploading real photos,** re-run Lighthouse on a product page; the first view of each photo comes from the database, later views from Vercel's edge.

Metric	Good	Measured (mobile, median)	Where to measure
LCP	≤ 2.5 s	home 1.13 s · product 1.55 s · shop 2.81 s	PageSpeed Insights, mobile

Metric	Good	Measured (mobile, median)	Where to measure
INP	≤ 200 ms	not measurable without real users (TBT 141–394 ms as a lab proxy)	PageSpeed Insights / Chrome DevTools
CLS	≤ 0.1	0 – 0.001	PageSpeed Insights / Lighthouse
First-load weight	< 1.5 MB	374–384 KB	DevTools Network tab

2. Security

Passive checks only: headers, redirects, certificates, cookie flags and plain requests to known paths. No fuzzing, brute force, injection or scanners.

Observation	Risk	Status
HTTPS: both hosts redirect HTTP→HTTPS; certificates valid (API: Let's Encrypt, to 22 Dec 2026; store: Google Trust Services, to 29 Jan 2027)	None today; the API certificate must auto-renew	**OK**
HSTS: store `max-age=63072000; includeSubDomains` ; API `max-age=31536000; includeSubDomains`	—	**OK**
Store headers: X-Content-Type-Options, X-Frame-Options DENY, Referrer-Policy, Permissions-Policy (camera, mic, location, payment off)	—	**OK**
Store CSP is `Content-Security-Policy-Report-Only` (deliberate first step)	Reports problems but does not yet block injected scripts	**CHECK**
API headers: `default-src 'none'; frame-ancestors 'none'` , nosniff, DENY, `Cross-Origin-Resource-Policy: same-site` , `X-Robots-Tag: noindex` ; no `Server` or `X-Powered-By` header	—	**OK**
Owner login: cookie `Secure; HttpOnly; SameSite=Strict` ; requests without `X-Requested-With: weft-admin` refused (400); login limited to 5/min plus account lockout	Cookie theft and CSRF are blocked	**OK**
Cookie-key encryption: data-protection keys stored in the database encrypted with a certificate (verified: 1 of 1 key encrypted)	Someone reading the database cannot forge the login cookie	**OK**
Admin API: `/api/admin/orders` , `/api/admin/dashboard` , `/api/auth/me` → 401 without login	—	**OK**
Checkout: server-side validation (FluentValidation, length caps), idempotency keys, stock and price re-checked, 10 orders per 10 min per IP; real client IP passed by Vercel with a shared secret, so a faked `X-Forwarded-For` cannot reset limits (verified by the API test suite against the same code: 429)	Spam is rate-limited; no CAPTCHA	**OK**
Exposure: `/.env` , `/.git/config` , `/web.config` , `/appsettings.json` , `/openapi/v1.json` , `/swagger` , `/logs/` → 404 on both hosts; `.map` files → 403; no keys or connection strings in 631 KB of client JavaScript	—	**OK**
Errors: unknown product → `application/problem+json` 404 with no stack trace	—	**OK**
Public repository (github.com/xYoussefJoo/WEFT). Defaults removed in this review (commit 6b1ed35), but git history still shows the database server and user; MonsterASP's database accepts internet connections	Only the database password protects the data	**FIX**
Dependencies: npm production 0; npm dev-only 8 moderate (ESLint tooling, not shipped); .NET 0 (Pkcs pinned to 10.0.14); GitHub vulnerability alerts disabled; secret scanning enabled	New CVEs would go unnoticed	**FIX**
Local development points at the production database	A local run can write test data or an unencrypted key into production	**FIX**
Backups: no backup job (the old Postgres backup was removed with Supabase)	Products, orders and photos have no copy	**FIX**

Security headers to switch on later

The store already serves these from `frontend/next.config.ts`. After about a week with no CSP reports in the browser console, change the key from `Content-Security-Policy-Report-Only` to `Content-Security-Policy`:

```
{ key: "Content-Security-Policy",   // was: Content-Security-Policy-Report-Only
  value: "default-src 'self'; img-src 'self' data: blob: https:; font-src 'self'; " +
         "style-src 'self' 'unsafe-inline'; script-src 'self' 'unsafe-inline'; connect-src 'self'; " +
         "frame-ancestors 'none'; base-uri 'self'; form-action 'self'" },
{ key: "Strict-Transport-Security", value: "max-age=63072000; includeSubDomains; preload" } // add preload
once on the final domain
```

Checkout and login hardening

- **Already in place:** server-side validation with length caps, idempotency, rate limits, CSRF header, stock and price re-check.
- **If spam orders appear,** add Cloudflare Turnstile to checkout (free, no puzzles for real users) and verify the token in `PlaceOrderHandler`.
- **Change the database password** in the MonsterASP panel, then update `web.config` on the server and user-secrets on the PC.

Preview and launch hygiene

- **Fix `NEXT_PUBLIC_SITE_URL` in Vercel** (now `https://weft.vercel.app`) to `https://weft-xi-two.vercel.app`, or to the client's own domain at launch, then redeploy. It feeds the canonical tag, share links and sitemap.
- **At launch on the client's domain:** also update `Site__PublicUrl` on MonsterASP and `AllowedHosts` if the API gets its own domain.
- **Vercel plan:** the Hobby plan does not allow commercial sites; a client store needs Pro or a team plan.

3. SEO and sharing

Item	Observation	Status
Title and description	"WEFT | The Thread Co.", bilingual description; product pages use the product name	**OK**
Open Graph / Twitter	1200×630 image with alt text, summary_large_image; share bots (WhatsApp, Facebook, Twitter) receive the tags in `<head>`	**OK**
Canonical, og:url, og:image, sitemap	All point to `https://weft.vercel.app` instead of the live domain	**FIX**
Product meta description for browsers	Next.js streams it after the head for normal browsers (Lighthouse SEO 92 on product); Google renders it	**CHECK**
robots.txt	Allows the store, disallows /admin and /api; admin also sends `X-Robots-Tag: noindex`	**OK**
Viewport, theme-color, language	`width=device-width`, `#141414`, `lang="ar" dir="rtl"`	**OK**
Accessibility	Lighthouse 100 on home and product after fixing contrast (4.48→5.1) and product-card labels	**OK**

4. How to verify the CHECK items

Goal	Tool / command
Real Core Web Vitals (incl. INP) once there is traffic	pagespeed.web.dev for https://weft-xi-two.vercel.app (mobile and desktop); WebPageTest.org for filmstrip and waterfall
CSP: nothing legitimate is blocked	Browse every page and the admin with DevTools Console open; look for "Report Only" CSP messages. No messages for a week → enforce
HTTP security headers	securityheaders.com; or `curl -sI https://weft-xi-two.vercel.app/` and `curl -sI https://weft.runasp.net/health`

Goal	Tool / command
TLS and certificate renewal	MDN HTTP Observatory; SSL Labs for weft.runasp.net; renewal check: `openssl s_client -connect weft.runasp.net:443 | openssl x509 -noout -enddate` after 22 Nov 2026
Idle sleep / cold start	Leave the site idle 30 minutes, then `curl -w "%{time_total}" -o NUL https://weft.runasp.net/health`; add UptimeRobot on /health
Photos through the edge	After uploading photos: `curl -sI https://weft-xi-two.vercel.app/api/media/<key>` twice, expect `X-Vercel-Cache: HIT`
Product meta description in Google	Google Search Console → URL Inspection → "View crawled page"
Page weight and lazy-loading	Chrome DevTools → Network, throttle to Slow 4G, tick "Disable cache"
Accessibility	Lighthouse accessibility audit; axe DevTools extension
Dependency vulnerabilities	`npm audit --omit=dev` in frontend; `dotnet list package --vulnerable --include-transitive` in backend; enable GitHub vulnerability alerts

5. Priority actions

1. **Set** `NEXT_PUBLIC_SITE_URL` to `https://weft-xi-two.vercel.app` in Vercel and redeploy. Confirm: View Source shows the right canonical, and `/sitemap.xml` lists the right domain.
2. **Set up database backups** (MonsterASP panel backup, or a scheduled `.bacpac` export). Confirm by restoring one copy to a test database. Photos live there too.
3. **Make the GitHub repo private and change the database password** in the MonsterASP panel (then update the server's `web.config` and user-secrets). Confirm: `/health` stays Healthy.
4. **Connect a real email sender** (e.g. Resend or Brevo) so the owner hears about new orders. Confirm with one test order.
5. **Turn on GitHub vulnerability alerts** (Settings → Security; alerts only, no automatic PRs). Confirm: the Security tab shows "Dependabot alerts: enabled".
6. **Add an uptime monitor** on `https://weft.runasp.net/health` every 5 minutes. Confirm: the monitor is green and the cold-start test is fast.
7. **Use a separate development database** for local work. Confirm: local user-secrets no longer contain the production connection.
8. **Enforce the CSP** after a week without reports, and polish the shop page LCP. Confirm with Lighthouse and the browser console.

6. Capacity estimate (modelled)

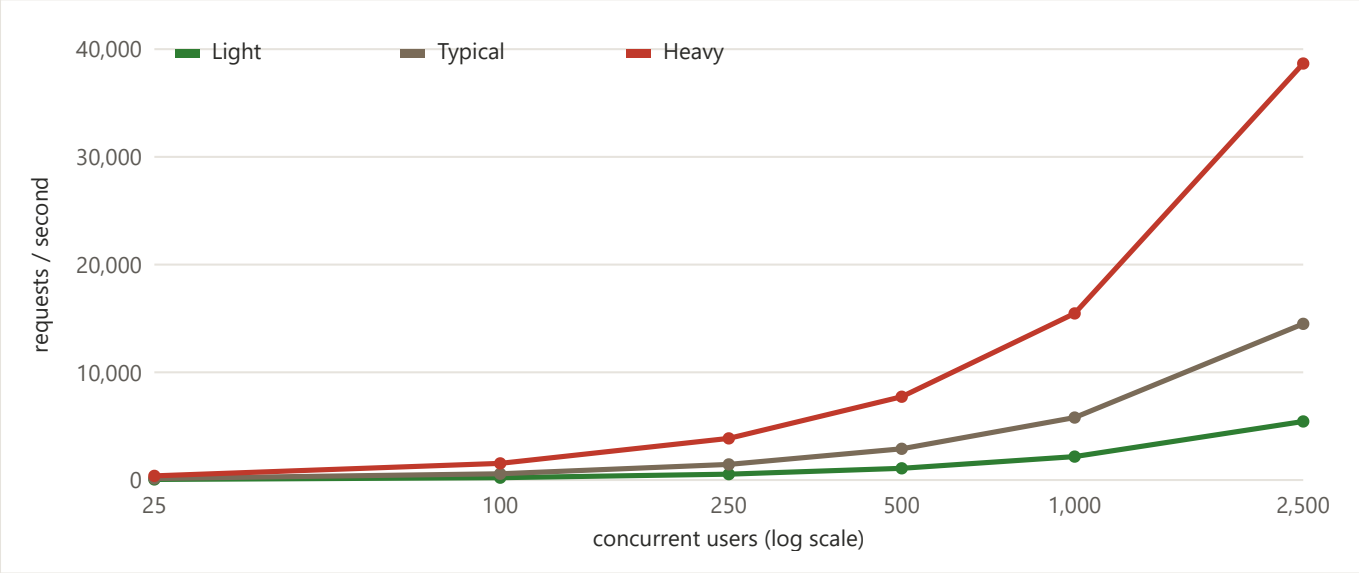
This section is a calculation, not a measurement.

No load was generated: the API runs on MonsterASP's free plan (256 MB memory), and a load test could get it throttled. The request count (29 per first visit) and first-visit size (377 KB) are measured; everything else follows from the formula.

```
requests/sec = (concurrent users / read time in seconds) × requests per visit
visits/sec   = concurrent users / read time            (typical scenario: 5 s)
bandwidth    = visits/sec × first-visit MB × 8          (Mbps)
transfer/hr  = visits/sec × 3600 × first-visit MB       (GB = MB / 1024)
```

Scenario	Requests per visit	Read time	Reasoning
Light	17.4	8 s	Cached assets, visitor skims one page
Typical	29	5 s	Measured first-visit request count; normal browsing
Heavy	46.4	3 s	Cold cache, fast scrolling, every product opened

Requests per second against concurrent users (calculation, not measured)



Concurrent users	Light (req/s)	Typical (req/s)	Heavy (req/s)
25	54	145	387
100	217	580	1,547
250	544	1,450	3,867
500	1,088	2,900	7,733
1,000	2,175	5,800	15,467
2,500	5,438	14,500	38,667

Bandwidth check (typical scenario, first visit 377 KB, calculation)

Concurrent users	Visits/sec	Bandwidth	Transfer per hour
100	20	59 Mbps	25.9 GB
500	100	295 Mbps	129.4 GB
1,000	200	589 Mbps	258.9 GB

How to read this

Most of these requests are static files and cached API reads served by Vercel's CDN, so request rate is rarely the limit. **Plan quotas bind first:** Vercel's data-transfer allowance, and MonsterASP's free-plan limits on memory and traffic. The real bottleneck is the dynamic endpoint (checkout writes to SQL Server on a 256 MB server), which is rate-limited to 10 orders per 10 minutes per IP. Check both hosting plans' limits before a launch or campaign.

Confirm the real limits with `docs/reports/weft-loadtest.js` (k6): it ramps to 100 virtual users on the store pages and sends one deliberately refused order per minute, so nothing is saved and no emails go out. Run it only against your own deployment, outside peak hours.

Assumptions: 29 requests and 377 KB per first visit (measured, Lighthouse median); read times 8/5/3 s; request multipliers 0.6× and 1.6×; repeat visits are much lighter because assets are cached.
Limitations: findings come from the publicly served content and the source code at the time of review (10 Nov 2026); no intrusive or active security testing was performed; lab measurements from Cairo only. A PageSpeed Insights run, a securityheaders.com result and a k6 summary would let this report be updated with field data.